

Unbounded Recursion in Deserialization #458

✓ Closed



DavidBuchanan314 opened on Feb 22, 2024 · edited by DavidBuchanan314

Edits ...

orjson does not limit its maximum recursion depth during deserialisation, so deserialising very deeply nested objects will overflow the native call stack. On my system (Fedora 39, aarch64), this results in a segfault. Python's native json module handles this slightly more gracefully.

```
import json
import orjson

nested = b'["*10000000 + b']'*10000000

try:
    json.loads(nested)
except RecursionError:
    print("RecursionError") # handled gracefully

try:
    orjson.loads(nested) # Segmentation fault (core dumped)
except RecursionError:
    print("RecursionError")
```

`orjson.dumps()` also appears to handle recursion limits gracefully, throwing `TypeError: Recursion limit reached` (it would be nice if it threw a `RecursionError`, though).



 **DavidBuchanan314** changed the title ~~Unbounded Recursion~~ Unbounded Recursion in Deserialization on Feb 22, 2024



Zaczero on Feb 22, 2024 · edited by Zaczero

Edits ...

I believe this is a high severity security issue (denial of service). The attack complexity is low, and the vector is network. Any application parsing untrusted user input would be vulnerable to it. <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?vector=AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H&version=3.1>

In my case it's enough that the message size is of 2MB (`b'[' * 1000000 + b']' * 1000000`).

Given the popularity of this project, I would recommend the maintainers set up a security policy to allow for safe disclosure of similar issues in the future. <https://github.com/ijl/orjson/security>



rds76 mentioned this [on Feb 22, 2024](#)



HAOS Core: "Fatal Python error: Segmentation fault" in RaspberryPi4 after 2024.02 upgrade related to threading [home-assistant/core#110538](#)



jcrist mentioned this [on Feb 23, 2024](#)



Add tests for encoding/decoding highly recursive messages [jcrist/msgspec#646](#)

ijl on Feb 24, 2024

Owner



[3.9.15](#)



ijl closed this as [completed](#) [on Feb 24, 2024](#)

Zaczero on Feb 26, 2024



This issue has been assigned [CVE-2024-27454](#).

I have prepared a blog post talking about the vulnerability:

<https://monicz.dev/CVE-2024-27454>

Thank you DavidBuchanan314 for the report 🙏.

♥ 1

Sign up for free

to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

No branches or pull requests

Participants

